



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





Simulación de una Auditoría

Módulo 10

Simular una auditoría OT: guía completa

Simular una auditoría es una de las herramientas más eficaces para comprender cómo se estructura, ejecuta y presenta este proceso en entornos reales. En el contexto OT, además, permite practicar el enfoque técnico sin comprometer la operación industrial.

Roles Típicos

Rol	Responsabilidades principales
Auditor líder	Coordina, entrevista, recoge evidencias, dirige el informe.
Co-auditor técnico	Inspecciona configuraciones, redes, accesos, backups.
Responsable OT	Representa el entorno industrial: planta, SCADA, PLCs.
Responsable IT	Explica los controles IT y sus conexiones con OT.
Responsable de seguridad / CISO	Presenta políticas, planes, formación y análisis de riesgos.
Testigo / relator	Toma notas para el informe, asegura trazabilidad.

Simular una auditoría OT: guía completa

Contenido del informe final de auditoría

El informe debe contener una visión completa del proceso y los hallazgos. Se recomienda dividirlo en **dos versiones**: una **técnica** y otra **ejecutiva**.

Formato técnico (para equipos IT/OT)

- Introducción: fechas, alcance, equipo auditor.
- Entorno evaluado: sistemas revisados, red, activos, etc.
- Hallazgos: por categorías (acceso, red, continuidad, formación, etc.)
- Nivel de riesgo de cada hallazgo: alto, medio, bajo.
- Evidencias técnicas: logs, capturas, planos de red, entrevistas.
- Acciones recomendadas: detalladas y con responsable propuesto.

Simular una auditoría OT: guía completa

Formato ejecutivo (para dirección / cumplimiento)

- Resumen ejecutivo del estado general.
- Principales hallazgos destacados y riesgos críticos.
- Valoración global de cumplimiento normativo (NIS2, ISO, 62443, etc.).
- Recomendaciones estratégicas.
- Propuesta de cronograma para acciones.

Presentación oral de resultados (opcional)

- Ideal como cierre de la simulación. Debe incluir:
- Diapositivas con 3–5 hallazgos clave.
- Gráficos de criticidad.
- Comparativa entre situación actual y estado deseado.
- Preguntas de la “dirección” (interpretadas por otros alumnos o instructores).

Simular una auditoría OT: guía completa

Solicitud de plan de acción

- Al finalizar la auditoría, el equipo auditor debe:
- Solicitar formalmente un **plan de acción correctivo**.
- Este debe incluir:
 - Qué acción se tomará para cada hallazgo.
 - Responsable asignado.
 - Plazo estimado.
 - Métrica de cumplimiento o verificación.
- **Formato sencillo del plan de acción:**

Hallazgo Nº	Acción Correctiva	Responsable	Fecha límite	Estado
1	Segmentar red OT	Resp. IT	30 días	Pendiente

Simular una auditoría OT: guía completa

Otros aspectos clave para incluir en la simulación

- **Respeto al rol:** cada persona debe actuar como su personaje.
- **Control del tiempo:** definir tiempo para entrevistas, análisis y redacción.
- **Entorno realista:** si es posible, usar una maqueta de red, esquema SCADA o entorno simulado.
- **Revisión del instructor:** analizar si el informe es objetivo, útil y ejecutable.

Resultado final esperado

- Los participantes deben entregar:
- Informe técnico.
- Informe ejecutivo o resumen.
- Presentación de hallazgos (opcional).
- Plan de acción propuesto.